Моделі загроз та моделі порушника

“Для створення моделі загроз необхідно скласти перелік суттєвих загроз, описати методи і способи їхнього здійснення.

Необхідно визначити, якими з можливих способів можуть здійснюватися загрози в АС:

- технічними каналами, що включають канали побічних електромагнітних випромінювань і наводок, акустичні, оптичні, радіо- та радіотехнічні, хімічні та інші канали;
- каналами спеціального впливу шляхом формування полів і сигналів з метою руйнування системи захисту або порушення цілісності інформації;
- несанкціонованим доступом шляхом підключення до апаратури та ліній зв’язку, маскування під зареєстрованого користувача, подолання заходів захисту з метою використання інформації або нав’язування хибної інформації, застосування закладних пристроїв чи програм та вкорінення комп’ютерних вірусів.

Загрози для інформації, що обробляється в АС, залежать від характеристик ОС, фізичного середовища, персоналу, технологій обробки та інших чинників і можуть мати об'єктивну або суб'єктивну природу. Загрози, що мають суб'єктивну природу, поділяються на випадкові (ненавмисні) та навмисні. Мають бути визначені основні види загроз для безпеки інформації, які можуть бути реалізовані стосовно АС і повинні враховуватись у моделі загроз, наприклад:

- зміна умов фізичного середовища (стихійні лиха і аварії, як землетрус, повінь, пожежа або інші випадкові події);
- збої і відмови у роботі обладнання та технічних засобів АС;
- наслідки помилок під час проектування та розробки компонентів АС (технічних засобів, технології обробки інформації, програмних засобів, засобів захисту, структур даних тощо);
- помилки персоналу (користувачів) АС під час експлуатації;
- навмисні дії (спроби) потенційних порушників.

Необхідно визначити перелік можливих загроз і класифікувати їх за результатом впливу на інформацію, тобто на порушення яких властивостей вони спрямовані (конфіденційності, цілісності та доступності інформації), а також порушення спостережності та керованості АС.

Випадковими загрозами суб’єктивної природи (дії, які здійснюються персоналом або користувачами по неуважності, недбалості, незнанню тощо, але без навмисного наміру) можуть бути:

- дії, що призводять до відмови АС (окремих компонентів), руйнування апаратних, програмних, інформаційних ресурсів (обладнання, каналів зв’язку, видалення даних, програм та ін.);

- ненавмисне пошкодження носіїв інформації;
- неправомірна зміна режимів роботи АС (окремих компонентів, обладнання, ПЗ тощо), ініціювання тестуючих або технологічних процесів, які здатні призвести до незворотних змін у системі (наприклад, форматування носіїв інформації);
- неумисне зараження ПЗ комп'ютерними вірусами;
- невиконання вимог до організаційних заходів захисту чинних в АС розпорядчих документів;
- помилки під час введення даних в систему, виведення даних за невірними адресами пристроїв, внутрішніх і зовнішніх абонентів тощо;
- будь-які дії, що можуть призвести до розголошення конфіденційних відомостей, атрибутів розмежування доступу, втрати атрибутів тощо;
- неправомірне впровадження і використання забороненого політикою безпеки ПЗ (наприклад, навчальні та ігрові програми, системне і прикладне забезпечення та ін.);
- наслідки некомпетентного застосування засобів захисту;
- інші.

Навмисними загрозами суб'єктивної природи, спрямованими на дезорганізацію роботи АС (окремих компонентів) або виведення її з ладу, проникнення в систему і одержання можливості несанкціонованого доступу до її ресурсів, можуть бути:

- порушення фізичної цілісності АС (окремих компонентів, пристроїв, обладнання, носіїв інформації);
- порушення режимів функціонування (виведення з ладу) систем життєзабезпечення АС (електроживлення, уземлення, охоронної сигналізації, вентиляції та ін.);
- порушення режимів функціонування АС (обладнання і ПЗ);
- впровадження і використання комп'ютерних вірусів, закладних (апаратних і програмних) і підслуховуючих пристроїв, інших засобів розвідки;
- використання засобів перехоплення побічних електромагнітних випромінювань і наводів, акусто-електричних перетворень інформаційних сигналів;
- використання (шантаж, підкуп тощо) з корисливою метою персоналу АС;
- крадіжки носіїв інформації, виробничих відходів (роздруків, записів, тощо);
- несанкціоноване копіювання носіїв інформації;
- читання залишкової інформації з оперативної пам'яті ЕОМ, зовнішніх накопичувачів;
- одержання атрибутів доступу з наступним їх використанням для маскування під зареєстрованого користувача ("маскарад");
- неправомірне підключення до каналів зв'язку, перехоплення даних, що передаються, аналіз трафіку тощо;

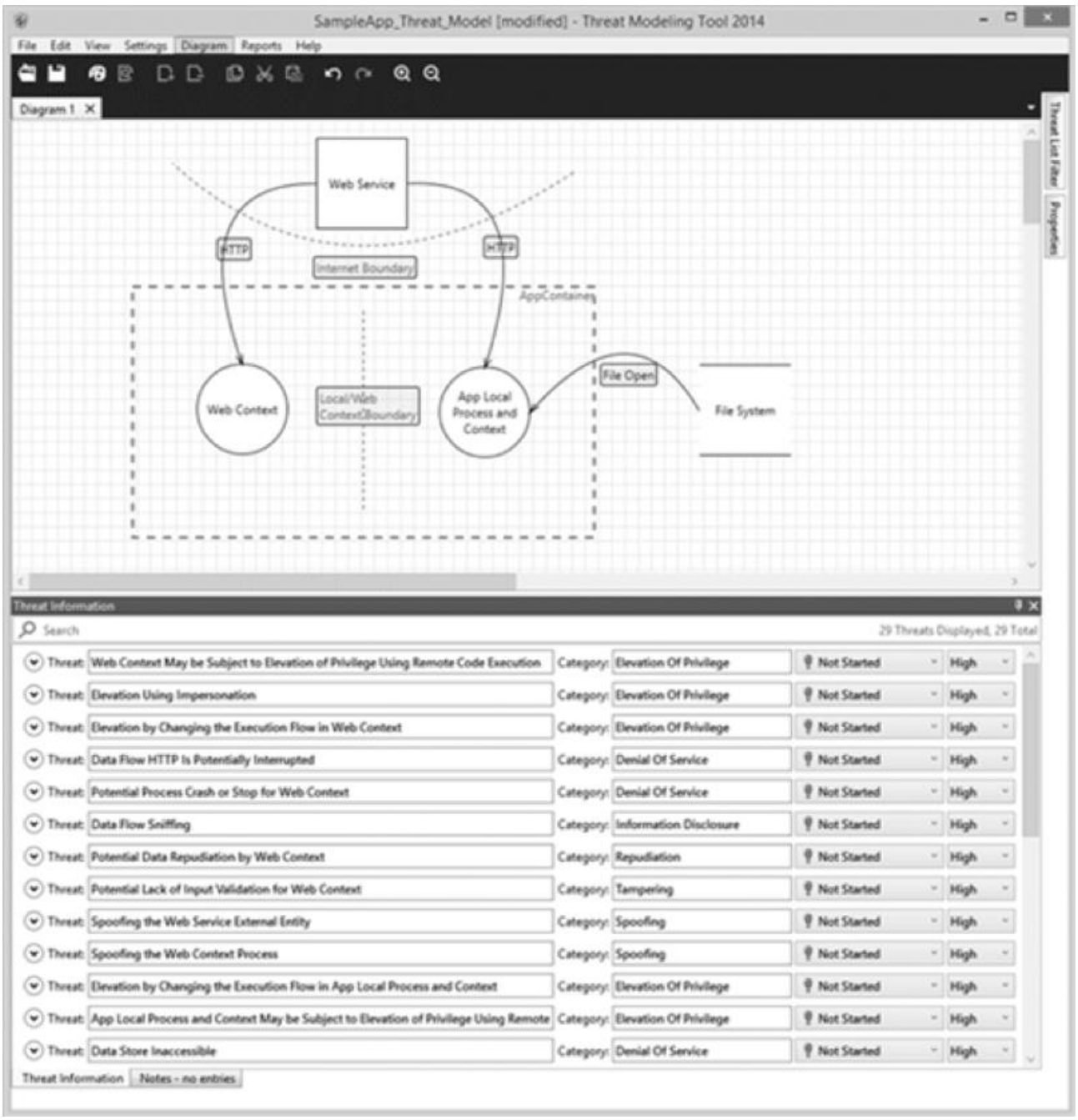
- впровадження і використання забороненого політикою безпеки ПЗ або несанкціоноване використання ПЗ, за допомогою якого можна одержати доступ до критичної інформації (наприклад, аналізаторів безпеки мереж);
- інші.

Перелік суттєвих загроз має бути максимально повним і деталізованим. Для кожної з загроз необхідно визначити:

- на порушення яких властивостей інформації або АС вона спрямована (рекомендується користуватись чотирма основними градаціями – порушення конфіденційності, цілісності, доступності інформації, а також порушення спостережності та керованості АС);
- джерела виникнення (які суб'єкти АС або суб'єкти, зовнішні по відношенню до неї, можуть ініціювати загрозу);
- можливі способи здійснення загроз."

Компанія Microsoft виклала у вільний доступ нову версію популярного інструменту для моделювання загроз - Microsoft Threat Modeling Tool 2014. Моделювання загроз є важливою частиною безпечного процесу розробки (Security Development Lifecycle, SDL), оскільки передбачає структурований підхід до створення сценаріїв потенційно небезпечних ситуацій. Все це сильно спрощує пошук слабких місць і вразливостей в системі безпеки та оцінку ризиків для розробки відповідних методів захисту.

Важлива зміна відбулося в логіці генерації загроз: тепер використовуються STRIDE-категорії, а загрози генеруються з урахуванням взаємодії елементів між собою. Передбачувані загрози для всієї моделі цілком можна побачити в режимі Analysis View.



Модель STRIDE (за матеріалами msdn.microsoft.com)

- **Spoofing identity**. Підміна ідентичності. An example of identity spoofing is illegally accessing and then using another user's authentication information, such as username and password.
- **Tampering with data**. Фальсифікація даних. Data tampering involves the malicious modification of data. Examples include unauthorized changes made to persistent data, such as that held in a database, and the alteration of data as it flows between two computers over an open network, such as the Internet.
- **Repudiation**. Відмова від авторства. Repudiation threats are associated with users who deny performing an action without other parties having any way to prove otherwise—for example, a user performs an illegal operation in a system that lacks the ability to trace the prohibited operations. **Nonrepudiation** refers to the ability of a system to counter repudiation

threats. For example, a user who purchases an item might have to sign for the item upon receipt. The vendor can then use the signed receipt as evidence that the user did receive the package.

- **Information disclosure**. Розголошення інформації. Information disclosure threats involve the exposure of information to individuals who are not supposed to have access to it—for example, the ability of users to read a file that they were not granted access to, or the ability of an intruder to read data in transit between two computers.
- **Denial of service**. Відмова в обслуговуванні Denial of service (DoS) attacks deny service to valid users—for example, by making a Web server temporarily unavailable or unusable. You must protect against certain types of DoS threats simply to improve system availability and reliability.

Elevation of privilege. Підвищення привілеїв. In this type of threat, an unprivileged user gains privileged access and thereby has sufficient access to compromise or destroy the entire system. Elevation of privilege threats include those situations in which an attacker has effectively penetrated all system defenses and become part of the trusted system itself, a dangerous situation indeed.

Приклад моделі загроз

1. Таблиця. Характеристика загроз ресурсам АС та їх наслідків (див. *Правове, нормативне та метрологічне забезпечення системи захисту інформації в Україні, 10 вип., 2005 р., М. Будько,МЕТОДИКА ОЦІНКИ ЗАГРОЗ ДЛЯ ІНФОРМАЦІЇ АВТОМАТИЗОВАНИХ СИСТЕМ*)

No	Вид загрози	Ймовір-ність	Що пору-шує	Рівень шкоди	Джерело
1	2	3	4	5	6
Навмисні загрози (з боку зловмисників)					
1.	Порушення фізичної цілісності АС (її окремих компонентів), пристроїв, обладнання, носіїв інформації	висока	к, ц, д, с	непри–пустимо високий	внут. зовн.
2.	Доступ до даних з порушенням встановлених правил розмежування доступу з метою ознайомлення, модифікації, копіювання, знищення даних тощо	низька	к, ц, д, с	непри–пустимо високий	внут. зовн.
3.	Модифікація інформаційних ресурсів, в тому числі програмного забезпечення	низька	ц, д, с	непри–пустимо високий	внут. зовн.
4.	Несанкціоноване змінювання повноваження інших користувачів	низька	к, ц, д, с	непри–пустимо високий	внут. зовн.

5.	Порушення режимів функціонування (виведення з ладу) систем життєзабезпечення АС (електроживлення, заземлення, охоронної чи пожежної сигналізації, вентиляції та ін.)	висока	ц, д, с	непри–пустимо високий	внут. зовн.
6.	Порушення режимів функціонування АС (обладнання та ПЗ)	висока	к, ц, д, с	непри–пустимо високий	внут. зовн.
7.	Впровадження і використання комп'ютерних вірусів, закладних (апаратурних і програмних) і пристроїв для підслуховування, інших засобів технічної розвідки, навмисно включати до складу програмного забезпечення спеціальні блоки для порушення безпеки даних	висока	к, ц, д, с	середній	внут. зовн.
8.	Використання персоналу АС (шантаж, підкуп тощо) з корисливою метою	висока	к, ц, д, с	високий	внут. зовн.
9.	Видавання власних несанкціонованих запитів за запити операційної системи	середня	к, ц, д, с	середній	внут.
10.	Отримання захищених даних за допомогою спеціально організованої серії санкціонованих запитів	середня	к, ц, д, с	середній	внут. зовн.
11.	Читання залишкової інформації з оперативної	низька	к	високий	внут.

.

No	Вид загрози	Ймовір-ність	Що пору-шує	Рівень шкоди	Джерело
	та зовнішньої пам'яті ЕОМ				
12.	Одержання атрибутів доступу з наступним їх використанням для маскування під зареєстрованого користувача, незаконне розширювання своїх	низька	к, ц, д, с	непри–пустимо високий	внут. зовн.

	повноважень, видавання себе за зареєстрованого користувача, вивчання права доступу інших користувачів				
13.	Неправомірне підключення (в тому числі, наприклад, “врізання” в канал пар типу “модем – модем”) до каналів зв’язку, перехоплення даних, що передаються, зміна (модифікація) інформації повідомлень (в тому числі службової, наприклад, адрес передавача та отримувача повідомлень	непри–пусти–мо висока	к, ц, д, с	непри–пустимо високий	зовн.
14.	Маскування захищених даних під незахищені	Дуже висока	к	високий	внут.
15.	Впровадження і використання забороненого політикою безпеки ПЗ або несанкціоноване використання ПЗ, за допомогою якого можна одержати доступ до критичної інформації (наприклад, аналізаторів безпеки мереж) та ін.	висока	к, ц, д, с	високий	внут. зовн.
16.	Несанкціоноване копіювання носіїв інформації	висока	к	висока	внут.
17.	Крадіжки носіїв інформації, виробничих відходів (роздруківок, записів тощо)	низька	к	середній	внут.
18.	Фальсифікація фактів формування та видачі даних	висока	ц	високий	внут.
19.	Підтвердження отримання від деякого користувача даних, сформованих самим порушником	висока	ц	високий	внут.
20.	Підтвердження передачі якому–небудь користувачеві даних, які не передавалися	висока	ц	середній	внут.
21.	Фальсифікація фактів отримання даних	висока	ц	середній	внут.
22.	Розкриття змісту даних у каналах зв’язку	висока	к	високий	внут.
23.	Виконання аналізу потоку даних (трафіку)	висока	д, с	низький	внут. зовн.
24.	Змінювання потоку даних,	висока	ц, д, с	високий	внут.

	наприклад шляхом генерації несправжніх повідомлень для перевантаження системи				зовн.
25.	Переривання передачі потоку даних	дуже висока	ц, д	Непри-пустимо високий	внут. зовн.
26.	Виконання ініціації фіктивного з'єднання	середня	ц, д	високий	внут.
Випадкові загрози					
27.	Дії, що призводять до відмови АС чи окремих її елементів, руйнування апаратурних ресурсів (в тому числі обчислювальних ресурсів – процесорів та носіїв даних) та обладнання, в тому числі телекомунікаційного, засобів вводу/ виводу, програмних та інформаційних ресурсів (як базових так і прикладних, файлів, наборів даних тощо)	низька	к, ц, д, с	непри–пустимо високий	внут.

No	Вид загрози	Ймовір-ність	Що пору-шує	Рівень шкоди	Джерело
28.	Ненавмисне пошкодження носіїв інформації чи інформації, яка зберігається на цих носіях	низька	к, ц	низький	внут.
29.	Неправомірна зміна режимів роботи АС (її окремих компонентів, обладнання, програмних засобів тощо), ініціювання технологічних чи тестуючих процесів, які здатні призвести до незворотних змін у системі (наприклад форматування носіїв інформації)	низька	к, ц, д, с	непри–пустимо високий	внут.
30.	Невмисне зараження програмних засобів (ПЗ) комп'ютерними вірусами	значна	к, ц, д, с	непри–пустимо високий	внут.
31.	Невиконання організаційних	низька	к, ц,	непри–	внут.

	заходів щодо порядку і правил експлуатації чи використання ресурсів АС, передбачених “Планом ТЗІ”, посадовими чи іншими, в тому числі технологічними інструкціями		д, с	пустимо високий	
32.	Помилки при введені даних в систему, видачі даних за невірними адресами пристроїв, внутрішніх і зовнішніх абонентів тощо	низька	к, ц, д, с	високий	внут.
33.	Неправомірне впровадження і використання забороненого політикою безпеки програмного забезпечення (системне, прикладне ПЗ, навчальні та ігрові програми та ін.)	низька	к, ц, д, с	низький	внут.
34.	Некомпетентне застосування засобів захисту	висока	к, ц, д, с	високий	внут.
35.	Наслідки викривлень під час проектування та розробки компонентів АС (технічних засобів, технології обробки інформації, програмних засобів, засобів захисту, структур даних тощо);	низька	к, ц, д, с	непри–пустимо високий	внут.
Впливи природних факторів					
36.	Зміна умов фізичного середовища (стихійні лиха, як землетрус, повінь, пожежа і аварії або інші випадкові події)	низька	ц, д, с	непри–пустимо високий	зовн.
37.	Збої та відмови у роботі обладнання та технічних засобів АС, аварійне відключення живлення та т.п.	низька	ц, д, с	непри–пустимо високий	внут.
38.	Впливи природних завад (грозові розряди, іскріння в електромережах, під час електрозварювання та т.п.	низька	ц, д, с	низький	зовн.

<u>Модель порушника</u>

У кожному конкретному випадку, виходячи з технології обробки інформації, необхідно розробити модель порушника, яка повинна бути адекватна

реальному порушнику для даної АС. Модель порушника — абстрактний формалізований або неформалізований опис дій порушника, який відображає його практичні та теоретичні можливості, апріорні знання, час та місце дії і т.ін. По відношенню до АС порушники можуть бути внутрішніми (з числа співробітників, користувачів системи) або зовнішніми (сторонні особи або будь-які особи, що знаходяться за межами контрольованої зони).

Модель порушника повинна визначати:

- можливу мету порушника та її градацію за ступенями небезпечності для АС;
- категорії осіб, з числа яких може бути порушник.;
- припущення про кваліфікацію порушника;
- припущення про характер його дій.

Метою порушника можуть бути:

- отримання необхідної інформації у потрібному обсязі та асортименті;
- мати можливість вносити зміни в інформаційні потоки у відповідності зі своїми намірами (інтересами, планами);
- нанесення збитків шляхом знищення матеріальних та інформаційних цінностей.

Рекомендується класифікувати порушників <u>за рівнем можливостей</u>, що надаються їм засобами АС, наприклад, поділити на чотири рівні цих можливостей. Класифікація є ієрархічною, тобто кожний наступний рівень включає в себе функціональні можливості попереднього:

- перший рівень визначає найнижчий рівень можливостей ведення діалогу з АС — можливість запуску фіксованого набору завдань (програм), що реалізують заздалегідь передбачені функції обробки інформації;
- другий рівень визначається можливістю створення і запуску власних програм з новими функціями обробки інформації;
- третій рівень визначається можливістю управління функціонуванням АС, тобто впливом на базове програмне забезпечення системи і на склад і конфігурацію її устаткування;
- четвертий рівень визначається повним обсягом можливостей осіб, що здійснюють проектування, реалізацію, впровадження, супроводження програмно-апаратного забезпечення АС, аж до включення до складу АС власних засобів з новими функціями обробки інформації.

<u>За рівнем знань</u> про АС усіх порушників можна класифікувати як таких, що:

- володіють інформацією про функціональні особливості АС, основні закономірності формування в ній масивів даних та потоків запитів до них, вміють користуватися штатними засобами;
- володіють високим рівнем знань та досвідом роботи з технічними засобами системи та їхнього обслуговування;

- володіють високим рівнем знань у галузі обчислювальної техніки та програмування, проектування та експлуатації АС;
- володіють інформацією про функції та механізм дії засобів захисту.

За використовуваними методами і способами порушників можна класифікувати як таких, що:
- використовують виключно агентурні методи одержання відомостей;
- використовують пасивні технічні засоби перехоплення інформаційних сигналів;
- використовують виключно штатні засоби АС або недоліки проектування КСЗІ для реалізації спроб НСД;
- використовують способи і засоби активного впливу на АС, що змінюють конфігурацію системи (підключення додаткових або модифікація штатних технічних засобів, підключення до каналів передачі даних, впровадження і використання спеціального ПЗ тощо).

За місцем здійснення дії можуть класифікуватись:
- без одержання доступу на контрольовану територію організації (АС);
- з одержанням доступу на контрольовану територію, але без доступу до технічних засобів АС;
- з одержанням доступу до робочих місць кінцевих (у тому числі віддалених) користувачів АС;
- з одержанням доступу до місць накопичення і зберігання даних (баз даних, архівів, АРМ відповідних адміністраторів тощо);
- з одержанням доступу до засобів адміністрування АС і засобів керування КСЗІ.”